AGRITRUST AI

ALTERNATIVE CREDIT SCORING PLATFORM

Security Review Report

TARGET
AgriTrust AI Dual Portal (FastAPI + Next.js)

REVIEW DATE
24 October 2026

METHODOLOGY
Source Review + Live Black-Box Probing

CLASSIFICATION
Internal / Confidential

STATUS
Open — Remediation Required Before Deployment

Executive Headline: Authorisation Held Up; Deployment Posture Failed

The core authorisation model held up under attack, but the overall deployment posture did not. A working bank-officer login and the production JWT signing secret are both committed/published, rendering a public deployment compromised on day one.

1. FINDING SEVERITY BREAKDOWN

SEVERITY	COUNT	IMPACT & CONTEXT
CRITICAL	2	Direct compromise of all borrower data or total usurpation of the JWT signing trust root.
HIGH	5	Practical abuse paths (brute-force exposure, token theft, service DoS) or direct privacy breaches.
MEDIUM	8	Defense-in-depth gaps that significantly escalate operational risk when combined.
LOW	4	Code hardening, health diagnostic leaks, and overall security hygiene issues.
VERIFIED	10	Security controls tested and verified to operate as designed.

2. EXECUTIVE SUMMARY & INVENTORY OF FINDINGS

ID	FINDING DESCRIPTION	SEVERITY
C1	Seeded bank-officer account with published credentials	CRITICAL
C2	JWT signing secret is committed default; forged tokens accepted	CRITICAL
H1	No rate limiting, lockout, or throttling on authentication endpoints	HIGH
H2	8-hour bearer token in localStorage with no revocation; client-side logout	HIGH
H3	No security headers on API or frontend; `X-Powered-By` disclosed	HIGH
H4	Upload cap applied after file read; no request-body limits (DoS vector)	HIGH
H5	Account enumeration enabled via registration endpoint response	HIGH
M1	Borrower proofs served inline from main app origin without sandboxing	MEDIUM
M2	Public API documentation & diagnostic endpoints expose attack surface	MEDIUM
M3	Weak password policy; missing MFA and account lifecycle controls	MEDIUM
M4	Auth events and PII reads un-audited; audit table lacks immutability	MEDIUM
M5	PII and documents stored unencrypted; no retention or erasure path	MEDIUM
M6	Dependency lower bounds admit vulnerable releases; no CI audit gate	MEDIUM

3. KEY VULNERABILITY FINDINGS & TECHNICAL EVIDENCE

C1: Seeded Bank-Officer Account with Published Credentials — CRITICAL

Where: Auth Seeder / Database Migration Scripts
Evidence: Hardcoded banker account credentials committed in repository and loaded on startup.
Impact: Complete administrative compromise of borrower records and credit evaluation controls.
Fix: Remove seed credentials; implement mandatory initial CLI bootstrap with secret generation.

C2: Default JWT Signing Secret & Unvalidated Claims — CRITICAL

Where: Backend Config / Auth Service
Evidence: JWT_SECRET defaults to a static repository string; forged signatures accepted.
Impact: Arbitrary token forgery allowing full identity impersonation. *Mitigation noted:* Database-authoritative role checks limit role escalations on existing user IDs.
Fix: Enforce non-default secret validation at app launch; enforce minimum 256-bit entropy.

H1: Missing Rate Limiting on Auth Endpoints — HIGH

Evidence: 25 failed login probes and 20 rapid registrations processed without HTTP 429 response.
Fix: Deploy rate limiting (e.g., slowapi / Redis rate limiter) on `/login` and `/register`.

H2: Un-revocable 8-Hour Bearer Token in localStorage — HIGH

Evidence: Tokens remain valid server-side after client sign-out; no server token blacklist.
Fix: Shift to short-lived access tokens with HttpOnly refresh cookies and server revocation.

H4: In-Memory File Buffering & Missing Body Limits — HIGH

Evidence: Upload checks evaluate filesize *after* reading entire payload, causing 305MB memory spikes.
Fix: Stream incoming uploads and enforce strict HTTP request body size limits at reverse proxy/edge.

4. REMEDIATION ROADMAP

PRIORITY	TARGET ACTION	OUTCOME / RISK REDUCTION
P0: Immediate	Disable seed logins, revoke static credentials (C1), and enforce strong runtime JWT secret validation (C2).	Eliminates full public compromise vector of the platform.
P0: Pre-Deploy	Implement rate limiting (H1) and align registration endpoint error messages (H5).	Prevents brute-force attacks and account enumeration.
P1: Pre-Pilot	Migrate storage from `localStorage` to secure cookies (H2), add full security headers (H3), and limit upload body sizes (H4).	Protects session integrity and guards against resource exhaustion.
P2: Hardening	Restrict diagnostic endpoints (M2), implement audit logging (M4), and clean up health/error responses (L1-L4).	Reduces residual attack surface and establishes regulatory compliance.

5. VERIFIED CONTROLS & FUNCTIONAL DEFECTS

CONTROL AREA	TEST PERFORMED	OBSERVED RESULT
Role Separation	Borrower token used against banker & admin endpoints	**PASS** (403 Forbidden)
Anonymous Access	Unauthenticated request to protected endpoints	**PASS** (401 Unauthorized)
Role Tampering	Forged `role=banker` claim in valid borrower token	**PASS** (DB role overrides claim)
Borrower Isolation	Borrower B accesses Borrower A's application data	**PASS** (404 Not Found)
Scoring Workflow Gate	Execution of scoring route prior to application verification	**PASS** (409 Conflict)
File Type Validation	HTML payload uploaded with disguised `.png` extension	**PASS** (422 Content Mismatch)
Path Traversal	Directory traversal payloads in file download keys	**PASS** (Safely Rejected)
SQL Injection	Malicious SQL payloads on login & query parameters	**PASS** (Parameterized)
Functional Defect	GET `/api/banker/reports` & `/api/borrower/reports`	**500 ERROR** (Subquery correlation)
Functional Defect	GET `/api/borrower/reports/{id}/letter`	**500 ERROR** (Unimported function)

6. PRODUCTION READINESS CHECKLIST

DOMAIN	REQUIREMENT FOR LIVE PRODUCTION TRAFFIC
Identity & Access	Manual banker provisioning; unique forced secrets; MFA enabled; initial password reset requirement.
Session Handling	Short-lived access tokens; server-backed session revocation; tokens removed from client `localStorage`.
Transport Security	TLS 1.2+ enforced with HSTS; proper reverse proxy headers; modern cipher suite configuration.
Edge Defense	Per-IP rate limits; strict body size limits at WAF; anti-automation / bot protection on auth routes.
Headers & CSP	Strict `Content-Security-Policy` with nonces, `X-Frame-Options: DENY`, and `X-Content-Type-Options: nosniff`.
Data & Privacy	AES-256 encryption for database & object store at rest; append-only audit trail; PII log redaction.

7. SCOPE, ASSUMPTIONS & LIMITATIONS

In Scope: Source review of FastAPI backend and Next.js frontend, authentication/authorisation modules, file storage handlers, dependency inventory, and live API probing against local test environments.

Out of Scope: Cloud infrastructure configuration (AWS/GCP IAM, WAF rules), network-layer DoS testing, third-party ML model internals (XGBoost/SHAP weights provenance), and physical environment controls.

Testing Isolation: All testing was conducted against disposable, non-production SQLite databases and isolated upload folders. Temporary probe scripts were completely removed post-assessment.

Prepared for engineering and product owners. Contains security-sensitive details — do not publish or distribute externally.